

VEILFORGE

Independent Technical / Security / Grant Audit Report

English executive summary and scoring - 10 August 2026

OVERALL SCORE

9.0 / 10

Status: The technical foundation is strong. No reproducible BLOCKER, CRITICAL, HIGH, MEDIUM, or LOW severity material defect was identified in the current archive.

Technical confidence: Resolver/source-integrity, deterministic report identity, proof flow, local-first analysis, and release discipline appear solid.

Main reservation: Due to an npm proxy limitation in the audit environment, the clean-room npm/solc/browser chain could not be independently completed end-to-end here.

1 Short Decision

Final audit decision: PASS WITH WARNINGS. The current VeilForge V4 archive demonstrates a technically credible product base for a serious grant candidate. Source resolution, deterministic report identity, local-first analysis, proof/Registry security, and release engineering are implemented with a coherent systems mindset.

Strongest technical approval point: This is not just a working UI. The project addresses difficult layers together: Solidity project resolution, canonical source identity, report integrity, browser/CLI behavior, proof preparation, and CI/release verification.

2 Findings Summary

Severity	Count	Key condition	Grant impact	Status
BLOCKER	0	-	-	None
CRITICAL	0	-	-	None
HIGH	0	-	-	None
MEDIUM	0	-	-	None
LOW	0	-	-	None

3 Confirmed Strengths

- External GitHub Actions references are pinned to immutable full commit SHAs.
- The resolver security suite is part of the canonical release verification chain.
- Cross-browser acceptance covers Chromium, Firefox, and WebKit; Edge is included on main push.
- The canonical release artifact is tested directly on /app and /app#scanner routes.

VEILFORGE

Technical Architecture and Security Assessment

4

Resolver / Source-Integrity

Bare package imports, nested node_modules, traversal, absolute Unix/Windows paths, UNC forms, unsafe remappings, and symlink escape classes were reviewed. Observed behavior was either correct source selection or fail-closed rejection. No verified path was found that silently substituted an out-of-scope source while still producing a successful report.

Assessment: 9.3 / 10

5

Path / Filesystem Security

Traversal, mixed separators, absolute paths, and dependency-boundary scenarios did not reveal a route by which out-of-project sources could silently enter analysis.

Assessment: 9.2 / 10

6

Determinism / Report Integrity

LF, CRLF, CR, UTF-8 BOM, object insertion order, and different outer-folder names did not introduce unintended variation into canonical source identity. The report identity model appears resilient to semantically irrelevant environment differences.

Assessment: 9.4 / 10

7

Privacy / Local-First

No verified browser-side path was found that uploads Solidity source or dependency contents to an external analysis service through fetch, XHR, or telemetry behavior.

Assessment: 9.1 / 10

8

Proof / Wallet / Registry

The proof flow includes layered controls around account/chain changes, stale preflight, report mutation, and publisher/hash/receipt validation boundaries.

Assessment: 9.0 / 10

9

Browser and Canonical Artifact

Browser source normalization operates on Uint8Array / ArrayBuffer input and preserves fail-closed behavior for invalid UTF-8. The canonical release artifact is tested directly for /app and /app#scanner mount behavior, scanner visibility, page errors, and module/asset 404 classes.

VEILFORGE

Independent Validation and Evidence

10 Executed Checks

Check	Result	Comment
Root test suite	63 / 63 PASS	General repository verification passed.
V4 report integrity	48 / 48 PASS	Canonicalization and report-integrity behavior passed.
Proof security	8 / 8 PASS	Proof, publisher, and hash boundaries passed.
Release hardening	8 / 8 PASS	CI/release guardrail tests passed.
Release integrity	4 / 4 PASS	Release verification chain passed.
Standard JSON / browser bytes	6 / 6 PASS	Browser normalization without Buffer dependency passed.
Static V4 acceptance	4 / 4 PASS	Production V4 acceptance logic passed.
Static type / JSON validation	729 JS + 205 JSON PASS	Structural validation succeeded.
Release manifest	1,161 entries MATCH	Independent hash comparison matched.
GitHub Action pin scan	20 / 20 SHA	External action references are immutable.

11 Environment Limitation

The audit environment's internal npm proxy returned an access error for a lockfile dependency tarball, which prevented a full clean npm ci chain from completing here. As a result, some solc 0.8.24 compiler-dependent cases could not be re-executed in this environment.

This was not classified as a verified product defect. However, the clean-room npm ci -> solc -> real browser chain remains NOT INDEPENDENTLY VERIFIED in this report.

12 Benchmark and Analyzer

The maintained benchmark methodology includes repeated execution and nondeterminism comparison logic. No obvious benchmark-case special-casing, fixture-ID hard-coding, or direct answer leakage was identified in the reviewed analyzer sources.

The most valuable next confidence step would be a broader third-party Solidity corpus for external precision/recall validation.

VEILFORGE

Current Technical Scorecard

Area	Score	Short assessment
Architecture / product reality	9.0	The product layers are real, clear, and coherent.
Resolver / source integrity	9.3	Fail-closed boundaries and canonical source handling are strong.
Path / filesystem security	9.2	Strong resistance to traversal and out-of-project source inclusion.
Determinism / report integrity	9.4	Robust against semantically irrelevant environment variance.
Analyzer quality	8.2	Good internal structure; broader external corpus would improve confidence.
Benchmark credibility	8.3	Methodology is solid, though full live compiler reruns are still limited here.
Proof / Registry security	9.0	Publisher/hash/receipt constraints appear well layered.
Privacy / local-first	9.1	No verified source-upload path was identified.
CI / supply-chain	9.0	Immutable SHA pinning and a strong release gate are in place.
Release engineering	9.0	Canonical artifact and manifest discipline are strong.
Documentation / claims	9.0	Claims are broadly aligned with the current implementation.
Test-suite credibility	9.1	Broad security and regression coverage for a solo-built project.

OVERALL SCORE

9.0 / 10

Main factor preventing a higher score: not a core security failure, but the inability to complete the full clean-room dependency/solc/browser chain in this audit environment, plus the still-limited amount of broader third-party analyzer evidence.

13 Grant Technical Risk

Based on the current source archive and the validation evidence reviewed, no confirmed defect was found that would justify immediate technical rejection in a serious grant review. The project presents real implementation depth across security boundaries, deterministic identity, proof flow, browser/CLI behavior, and release verification.

VEILFORGE

Grant Readiness and Final Decision

14

Strongest Technical Approval Reasons

- Resolver and source-integrity boundaries are designed to fail closed.
- Canonical source/report identity and integrity linkage are unusually strong.
- The local-first analysis posture is credible; no source-upload path was verified.
- The proof/wallet/Registry flow separates account, chain, publisher, hash, and receipt constraints clearly.
- Immutable GitHub Actions pinning and canonical artifact verification strengthen supply-chain trust.
- For a solo-developed project, the security and regression-testing discipline is exceptionally strong.

15

Evidence That Would Improve Confidence Most

The single most valuable next evidence bundle would be a clean independent runner demonstrating successful npm ci + npm audit + exact solc 0.8.24 + full benchmark reruns + Chromium/Firefox/WebKit/Edge production acceptance in one immutable package.

A second high-value step would be an independent, versioned compatibility and accuracy corpus built from real open-source Hardhat / Foundry / OpenZeppelin projects.

16

Final Decision

PASS WITH WARNINGS

OVERALL SCORE

9.0 / 10

BLOCKER 0

CRITICAL 0

HIGH 0

MEDIUM 0

LOW 0

ZERO BLOCKERS ZERO CRITICAL FINDINGS ZERO HIGH FINDINGS

Question: Is there a reproducible technical defect serious enough that a Circle/Arc grant reviewer could reasonably reject the current project immediately?

NO. No confirmed HIGH+ defect was identified in the current archive in the categories that matter most for immediate rejection: source-integrity, path escape, privacy, report/proof integrity, or unexpected mainnet transaction behavior. The remaining reservation is about independent clean-room validation breadth, not a demonstrated core product break.